Replayable Control Points: A Fresh Bounded AI Authorization Audit

Public-safe fresh rerun

A public-source case study using a pinned Microsoft approval/governance repository and the DI² v0.3.1 local hardening candidate.

Publication	Grounded DI public exhibit | October 21, 2026
Status	Prepared for public-safe registry publication; no external posting beyond the authorized registry commit.
Scope	One frozen local replay package, one pinned public source snapshot, and one exact DI² v0.3.1 harness.

Grounded DI LLC | Neutral, bounded, reproducible evidence

Publication note

This book records one fresh, controlled local replay and the associated public-safe documentation package. It is an evidence summary, not a product certification, incident report, vulnerability declaration, or production-readiness decision. The package contains only this fresh rerun's book, report, verdict, replay boundary, manifest, and checksums; it does not include earlier exhibit books or executable source snapshots.

The native replay and the DI² v0.3.1 sidecar audit are separate lanes. Their results are intentionally not merged. A native result describes the target's selected replay path. A sidecar result describes bounded observations made by the local audit adapter and harness against the same frozen inputs.

Executive summary

VERIFIED: The fresh native replay completed offline with 216 PASS results, 11 OPA-CLI skips, and 0 failures. The fresh DI² v0.3.1 sidecar completed all 80 registered cases with 64 PASS assertions and 16 registered Microsoft safety assertions that failed; it reported 0 harness errors and 0 load errors.

VERIFIED: The DI² v0.3.1 candidate self-replay passed integrity, repeatability, mutation, expiry, receipt, and crash-recovery checks. Added control checks passed 9/9, and health mutations were detected 10/10.

INFERENCE: The 16 sidecar failures group into five bounded control-boundary issue families in the pinned local implementation: mutable approved inputs; incomplete effective argument binding; expiry sampled before the final dispatch boundary; conflicting or duplicate event delivery; and ordered-stage enforcement.

UNVERIFIED: These observations do not establish live-service behavior, a production incident, a Microsoft-wide or product-wide property, model-wide behavior, or knowledge, endorsement, or response by Microsoft.

Why replayable authorization matters

An approval is meaningful only if the action executed is the action that was approved, the approving actor and target remain bound to that action, expiry is enforced at the final effect boundary, and duplicate or conflicting delivery cannot change the result. A replay makes these questions inspectable with frozen inputs, repeatable runs, explicit state, and preserved evidence.

Replay is useful for two different purposes. The canonical native replay answers whether the target package behaves as designed under its selected tests. An optional sidecar audit asks whether a local, reusable control model detects selected authorization and dispatch boundary conditions. The second question is useful, but it is not a replacement for the first.

Artifact identities and scope

Artifact	Exact identity
Target archive	SHA-256: `be0540c28c6a3811012c36f461e32efaec8cf91cc7200b7289917cf4f4710cbf`
DI² harness	Version `v0.3.1`; SHA-256: `f45bf63b9ff622b00b697926e8cb941ebbbed763831e088423c4cab8be30c024`
Pinned public source	`https://github.com/microsoft/ai-agents-for-beginners` at commit `bb9fd0df2aed2969a403b6d083c34185cad0eb04`
Frozen case registry	SHA-256: `20cf185b705fb5e49f562d1cb794eb4915bde6229e224aa37e5f0cd9e0d7d341`
Added-control plan	SHA-256: `11ef771aefc51c4b340a23bb08f3c01a8b61e5151a466b7bbe57b5656dffe373`
Registry destination	`https://github.com/Grounded-DI/grounded-di-replay-certificate-registry`
Execution mode	Local, offline, frozen inputs; no model routes executed

VERIFIED: The harness identity was checked before execution. Archives with another version or another SHA-256 were not accepted for this rerun. No target source, harness source, or frozen input was modified during execution.

SCOPE: The package covers only the selected replay surfaces exposed by the target and the local sidecar adapter: callable and argument binding, approval-to-execution identity, expiry and clock placement, single-use and duplicate delivery, local receipt/state behavior, cancellation and crash recovery, dispatch/release boundaries, and target-specific authorization/evidence controls where implemented.

Method: canonical native replay versus optional DI² sidecar

The native lane ran the target package as designed, with the repository's selected offline/network guard. Its output is the canonical replay result for this audit package.

The sidecar lane ran the same frozen inputs through DI² v0.3.1 and the relevant local adapter or boundary. It retained separate state for in-memory and local SQLite persistence where those paths were exposed. The sidecar did not change the target source, claim to represent a remote service, or create production evidence.

The candidate self-replay ran two fresh result rounds and compared preserved result bytes, then exercised mutation, expiry, receipt, and crash-recovery checks. Five minimal targeted reproductions were also rerun; each produced a registered property failure rather than a harness or loading error. The public record summarizes those reproductions conceptually and omits payloads, line-level source details, and operational exploitation steps.

Fresh rerun results

Lane or control	Result	Meaning
Native selected replay	216 PASS; 11 OPA-CLI skips; 0 failures	Canonical result for the target's selected local replay
DI² v0.3.1 sidecar audit	64 PASS; 16 registered Microsoft safety assertions failed	Bounded local observations; not a target certification
Sidecar harness/load health	0 harness errors; 0 load errors	Runner completed all registered sidecar cases
DI² v0.3.1 self-replay	PASS	Integrity, repeatability, mutation, expiry, receipt, and crash checks completed
Added sidecar controls	9/9 PASS	Additional registered control checks
Health mutation detection	10/10 detected	Local mutation-health result

The two lanes must be read independently. A native pass is not erased by a sidecar observation, and a sidecar pass does not certify the target. The fresh rerun reproduced the same grouped sidecar outcome under the same pinned identities, which supports repeatability of this local observation only.

Five bounded control-boundary issue families

The following are public-safe family descriptions. They are **INFERENCE** from the registered sidecar assertions and fresh targeted reproductions, not claims about a remote service.

Mutable approved inputs

The sidecar observed paths where an input approved at one point could differ from the input used later in the local execution path. The public implication is a need to bind or snapshot effective inputs at approval and verify that binding again at execution.

Incomplete effective argument binding

The sidecar observed that not every effective callable argument was represented in the approval-to-execution identity. The public implication is a need for complete, deterministic binding of arguments that can change the action's meaning.

Expiry sampled before the final dispatch boundary

The sidecar observed a path where expiry was checked before intervening work rather than at the final release or dispatch boundary. The public implication is to place the decisive time check as close as practical to the effect boundary.

Conflicting or duplicate event delivery

The sidecar observed conflicting or duplicate delivery conditions in which event identity and single-use state needed stronger coordination. The public implication is to make event identity, conflict handling, and receipt consumption explicit and durable for the supported execution model.

Ordered-stage enforcement

The sidecar observed that required stages could be presented out of order in a tested local path. The public implication is to enforce the permitted stage transition order before release.

No family description above includes credentials, private files, personal data, hidden prompts, executable source snapshots, payloads, attack recipes, deployment-specific instructions, or instructions for accessing a live system.

Controls that passed and what they do establish

VERIFIED: The native selected replay completed without a reported failure, subject to its 11 OPA-CLI skips. This establishes only that the selected local native replay produced its recorded result under the frozen run configuration.

VERIFIED: DI² v0.3.1 self-replay passed integrity and repeatability checks, including preserved result comparisons, mutation checks, expiry checks, local receipt/state checks, and crash-recovery checks. This establishes that the candidate harness behaved consistently in this local synthetic test environment.

VERIFIED: Added controls passed 9/9, and the health suite detected 10/10 local mutations. This establishes the recorded behavior of those checks against the supplied local adapter and candidate harness.

VERIFIED: No sidecar harness or load errors were reported. This supports the conclusion that the 16 failed registered assertions were completed observations rather than unexecuted or malformed cases.

These passes do not certify the target, the repository, the harness outside this configuration, or any remote deployment.

What the audit does not establish

The following are **UNVERIFIED**, **UNTESTED**, or **UNSUPPORTED** by this package:

- live-service or production behavior, remote identity, network authorization, or external effects;
- a security incident, exploitability, severity, or Microsoft vulnerability classification;
- behavior outside the pinned commit, supplied archive, frozen case registry, adapter, and local runtime;
- whole-product, whole-company, cross-service, model-wide, or ecosystem-wide conclusions;
- continuous hostile-context behavior, all possible argument forms, all closure or reopen paths, or all asynchronous delivery semantics;
- the 11 OPA-CLI skips as positive or negative security results;
- proof of distributed exactly-once behavior or a strict real-world wall-clock guarantee;
- any Microsoft knowledge, endorsement, contact, suppression, response, or remediation;
- production readiness of DI² v0.3.1.

The package also does not attempt to infer legal conclusions from a local technical replay. Technical observations remain bounded to the tested path.

DI² v0.3.1 release classification

VERIFIED classification: `LOCAL SYNTHETIC HARDENING CANDIDATE; OPTIONAL PERSISTENT LOCAL GATE`.

VERIFIED: The candidate self-replay passed its local integrity, repeatability, mutation, expiry, receipt, and crash-recovery program.

UNVERIFIED: Production readiness remains unestablished. DI² v0.3.1 should be treated as a local hardening and audit candidate, not as a production authorization control or external certification.

Public-safety and responsible-disclosure note

This public package is intentionally minimized. It names the tested identities and summarizes control families without publishing exploit-ready content. It contains no credentials, personal data, private files, hidden prompts, executable Microsoft source snapshots, payloads, attack recipes, or deployment instructions.

The language is neutral: the sidecar observations are called registered safety assertions that failed or bounded local control-gap observations. No claim is made that Microsoft knew of, endorsed, received, suppressed, or responded to this package. Any future disclosure or coordination decision is outside this publication package and requires separate authorization.

Reproduction boundaries and citations

Reproduction is limited to a clean local environment with the exact target archive, exact DI² v0.3.1 harness, pinned public source commit, frozen case registry, added-control plan, and the preserved configuration record. Verify each SHA-256 before execution; reject any identity mismatch. Run the native lane as the target package specifies, then run the sidecar lane independently against the same frozen inputs. Preserve separate summaries, receipts, logs, and hashes.

Do not connect the reproduction to a live service, modify the target or harness, substitute a newer or older harness, or reuse an unverified archive. Do not interpret a skipped case as a pass or failure. Record any divergence between lanes as a counterexample and keep both lane results.

Public source citation: `https://github.com/microsoft/ai-agents-for-beginners` at commit `bb9fd0df2aed2969a403b6d083c34185cad0eb04`. The source scope is the pinned public repository snapshot used by the local package; the citation is not a claim about later commits or deployed behavior.

Evidence labels used in this book are deliberate: **VERIFIED** means recorded directly by the fresh local run or preserved identity check; **INFERENCE** means a conceptual grouping derived from those records; **UNVERIFIED** means not established by this package; **UNTESTED** means not exercised; and **UNSUPPORTED** means outside the supported path or evidence boundary.

Publication boundary: this package is prepared and posted as a new registry entry only. It does not replace, merge with, or revise prior registry records.